

Threat Model Template (STRIDE)

Threat Model Scope

In Scope Application(s)	
Participants	
Date Created	
Date Updated	

Diagram

Architecture Diagram: Add your architecture or data flow diagram (DFD) here before filling out threats. The DFD is the foundation for both STRIDE and MAESTRO analysis. To insert: Edit page → Insert → Files and images, or paste directly from your diagramming tool.

Add your diagram here

System Overview (Important Questions)

Answer important high level questions to inform the threat model.

LeanIX Application Criticality	
Where is the app / system hosted?	
Is the app externally exposed?	
Does the app handle sensitive data and/or PHI? If Yes, what's the annual volume? (< 500 500 - 1M 1M - 50M 50M - 100M 100M+)	
Where is PHI Stored? What PHI values are stored? Is PHI ever archived/purged/removed?	
Are there external users? Explain how you Identify, Authenticate and Authorize users?	
How do you handle secrets? (passwords, PINS, keys, access tokens)	
Do your logs allow you to track the actions of a user throughout a transaction? Where are your logs housed?	
Does your application use AI agents or call AI services for application functions? If yes, please complete the AI:MAESTRO threat model in addition to this STRIDE model and add the link to your MAESTRO model here.	

STRIDE Threat Analysis

Once we have a Data Flow Diagram (DFD), we can look at Threats in a systematic and repeatable way.

We use the Microsoft idea of six Threat categories and the acronym **STRIDE**:

Spoofing

Tampering

Repudiation

Information Disclosure

Denial of Service

Escalation of Privilege

Tips:

- Consider each threat category in turn and see where it could fit in the diagram.
- Get into character and think like an attacker as you scrutinize your own App / System.
- Focus on EXTERNAL Threats. Don't think about Internal Threats (inside the CoverMyMeds perimeter) for now because every internal component has some degree of trust.
- The categories are not rigid. You may consider a threat that doesn't fit neatly into a category, or seems to span multiple categories. Whichever category you choose to record it in is fine.

S – Spoofing

Someone (or something) pretends to be someone else (or something else). They're impersonating in an unauthorized way. It's an attack on **Authenticity**.

Examples include using stolen credentials, cloning a lookalike website to harvest data, redirecting traffic to a phony endpoint, lying about their location, re-writing cookies, re-writing query string parameters or post details, etc.

Look at your Data Flow Diagram and make a note wherever external Spoofing could possibly happen. Consider spoofed vendors or partners.

Suggestions:

- If one of your external users is compromised outside of CoverMyMeds (e.g. they're a victim of social engineering and their desktop computer and local account is pwned), the liability is probably with them and it's hard to see what you could do if they present valid credentials, other than MFA and access controls that limit them to their own data and no-one else's data.

List Any Existing Security Controls

e.g. MFA Okta

Where could spoofing happen?	Likelihood Very likely / likely / unlikely / very unlikely	Affected Users or Applications Who would be impacted?	Discoverable How would we know?	Impact High / Medium / Low	Risk = Likelihood x Impact
<i>e.g. A bad actor steals credentials of a CMM employee via a phishing attack.</i>	<i>e.g. likely</i>	<i>e.g. internal employee, all apps/data available for the compromised account.</i>	<i>e.g. we would not know, alerting is not currently set up for unusual user behavior</i>	<i>e.g. High impact</i>	<i>e.g. High</i>

T – Tampering

The attacker changes something, usually data or code. It's an attack on **Integrity and Reliability**.

Examples include defacing a web page, injecting poisoned data, altering code or configs to remove security, deleting log files to cover their tracks, etc.

Look at your Data Flow Diagram and make a note wherever external Tampering could possibly happen. Consider inputs from external entities like vendors, partners, users.

Suggestions:

- You probably have standard CoverMyMeds permissions that limit access to data, code, and configs at rest.
- You probably have standard CoverMyMeds TLS (HTTPS/SSH/SFTP) that prevents the interception of data, code, commands, and configs in transit.
- You probably sanitize inputs to prevent command injection and SQL injection.
- You may use digital signatures, hashes, checksum, digests, etc. to ensure documents and files are intact.

List Any Existing Security Controls

e.g. TLS

Where could tampering happen?	Likelihood Very likely / likely / unlikely / very unlikely	Affected Users or Applications Who would be impacted?	Discoverable How would we know?	Impact High / Medium / Low	Risk = Likelihood x Impact
<i>e.g. An attacker could take advantage of unvalidated form inputs, which could be used as part of an injection attack.</i>					

R – Repudiation

Someone denies performing an action, or falsely claims to have taken an action.

The real answer to Repudiation is:

- Identify and authenticate users to be confident about who is involved.
- Log activity well enough to be able to construct an audit trail and present a case of who, what, when, how.

List Any Existing Security Controls

e.g. DataDog Monitoring

Where are we not identifying users or not logging activity that we should?	Discoverable How would we know?	Impact High / Medium / Low	Risk = Likelihood x Impact
<i>Ex. Insufficient Logging in X function would allow an attacker to change PHI without an audit trail.</i>			

I – Information Disclosure

Someone gains access to sensitive or private information they have no right to see, or we inadvertently expose it. It's a lapse in **Confidentiality**.

The private or sensitive information could be files, PHI records, services, user names, host names, tech stack details, configs, source code, etc. It could be exposed any number of ways including unsecured storage, error messages, headers, banner messages, unencrypted transmission, careless sharing of information, etc.

Look at your Data Flow Diagram and make a note wherever external Information Disclosure could possibly happen. PHI and Secrets are the priorities.

Suggestions:

- You probably have identification and authentication of users.
- You probably have Role Based Access Controls (RBAC) that limit users to their own data.
- You probably have Encryption in transit (TLS) that prevents interception.
- You probably have Encryption and/or vaulting of passwords.
- You may have hardened workflows for password resets, error handling, etc. that don't give attackers more to work with.
- You inherit some degree of hardened configs and patched hosts that reduce vulnerabilities.

List Any Existing Security Controls

e.g. TLS Encryption

Where could information disclosure happen?	Likelihood Very likely / likely / unlikely / very unlikely	Affected Users or Applications Who would be impacted?	Discoverable How would we know?	Impact High / Medium / Low	Risk = Likelihood x Impact
<i>e.g. An attacker who has gained access via spoofing can download PHI via bulk download button.</i>					

D – Denial of Service

An attacker causes an application or system to be less accessible, or to perform in a degraded state, or to cause great expense, or otherwise make a service unviable or inoperable. It's an attack on **Availability**.

Examples include overwhelming a system with requests to exhaust resources and bring it to a crawl, causing a system to crash completely, causing a system to consume a billable resource to run up costs, locking out an account, etc.

Look at your Data Flow Diagram and make a note wherever a Denial of Service could possibly happen. Identify any billable resources, bottlenecks, or single points of failure (SPOFs).

Suggestions:

- In the data centers you inherit some protection from perimeter devices like Firewalls and WAFs.
- You probably have scalability from load balancing apps and clustering databases.
- You probably have DR Failover capabilities that allow you to run from the other data center if it all goes horribly wrong.
- You may have throttling or rate limiting to protect apps.
- You may have baselined availability, performance, resource consumption, etc. with monitoring that alerts you to anomalies.
- You inherit some degree of hardened configs and patched hosts that reduce vulnerabilities.

List Any Existing Security Controls

e.g. Rate Limiting

Where could denial of service happen?	Likelihood Very likely / likely / unlikely / very unlikely	Affected Users or Applications Who would be impacted?	Discoverable How would we know?	Impact High / Medium / Low	Risk = Likelihood x Impact

E – Escalation of Privilege

Someone manipulates the system to get more permissions and access than they were assigned. The goal is usually to access all the data, and/or gain all the permissions (root/admin). It's an attack on **Authorization**.

Look at your Data Flow Diagram and make a note wherever an external Privilege Escalation could possibly happen.

Identify any levels of user access. For example, read-users vs write-users, ordinary-users vs power-users, admin users, users limited to specific functions or data or views.

Suggestions:

- You probably have identification and authentication of users.
- You probably have Role Based Access Controls (RBAC) that limit users to their own data.
- You probably validate and sanitize user inputs to limit command injections.
- You may have dedicated Service Accounts with minimal privileges.
- You inherit some degree of hardened configs and patched hosts that reduce vulnerabilities.

List Any Existing Security Controls

e.g. RBAC

Where could privilege escalation happen?	Likelihood Very likely / likely / unlikely / very unlikely	Affected Users or Applications Who would be impacted?	Discoverable How would we know?	Impact High / Medium / Low	Risk = Likelihood x Impact

Follow Up – Remediation and Risk

Finish your threat model by identifying needed controls and residual risk.

Remediation / What can we fix?

Document any remediation plans and Jira Cards for risks identified in this model.

Risk Description	Control Name	Description	JIRA Card
<i>Ex. Insufficient Logging in X function would allow an attacker to change PHI without an audit trail.</i>	<i>e.g. Logging and Monitoring</i>	<i>Implement logging additional information to allow for a consistent audit trail in X function.</i>	<i>Jira Link</i>

What can't we fix?

Work with the Product Security team to add any *significant* new risks to One Trust.

Risk Description	JIRA Card
<i>Ex. Insufficient Logging in X function would allow an attacker to change PHI without an audit trail.</i>	<i>Jira Link</i>

What's Next?

As new workflows are added or scope is changed, revisit and revise this model to reflect the current state of the system.